



INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Course: BVWS103-OWASP Top 10 Vulnerabilities And
Exploitation Techniques(Broken Access Control)

Student Name: Abubakari-Sadique Hamidu

Student ID: 2025/FWSD/11392

Instructor: Aminu Iddris (CCNA, CompTIA, CEH, OSCP, CISSP,
CISM)

Title: Broken Access Control Vulnerability

Objective

- Understand Broken Access Control.
- Exploit unauthorized access.
- Apply mitigation using proper authorization.

Tools Used

- PHP
- Local web server (XAMPP/WAMP)
- Web browser

Exploiting Broken Access Control

Description

Broken Access Control occurs when a system does not properly restrict user actions. Users can access pages or resources they are not authorized to use.

Procedure

- Created a director : lab5_BrokenAccessControl
- Created three files inside the folder:
 - login.php
 - user_dashboard.php
 - admin_dashboard.php
- Logged in as a regular user.
- Manually accessed the admin page by changing the URL.

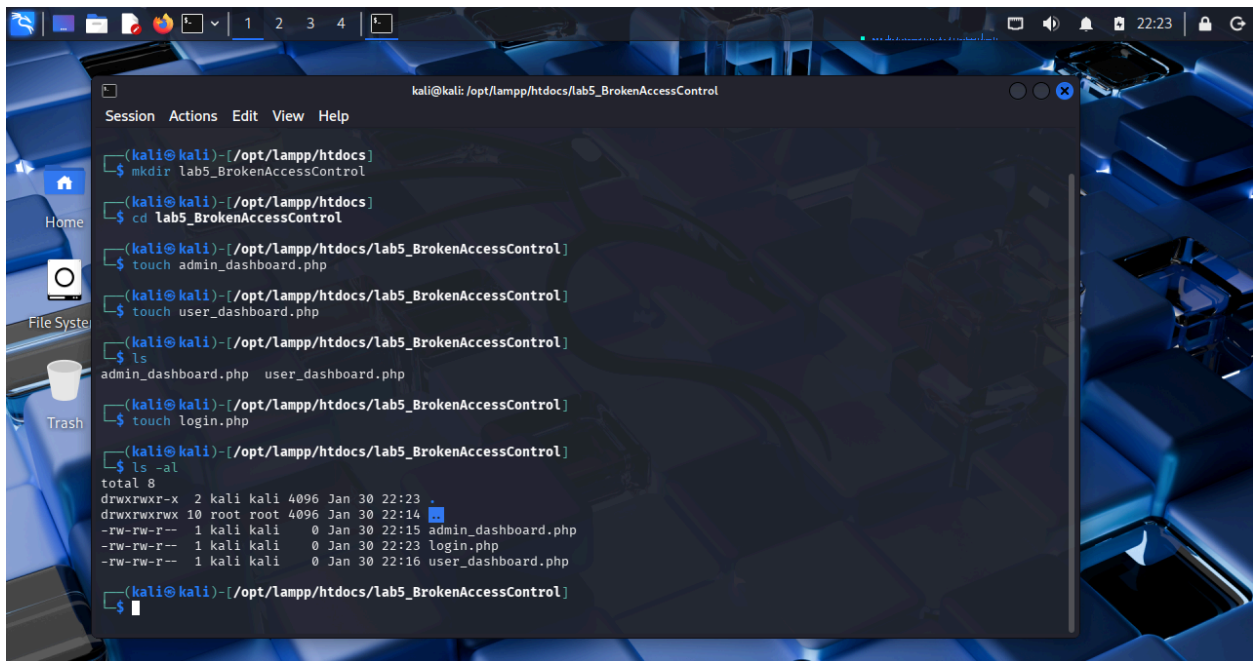
Exploit Performed

- Logged in with:
 - Username: user
 - Password: user123

- Changed URL to admin_dashboard.php
- Admin page loaded successfully without authorization.

Evidence

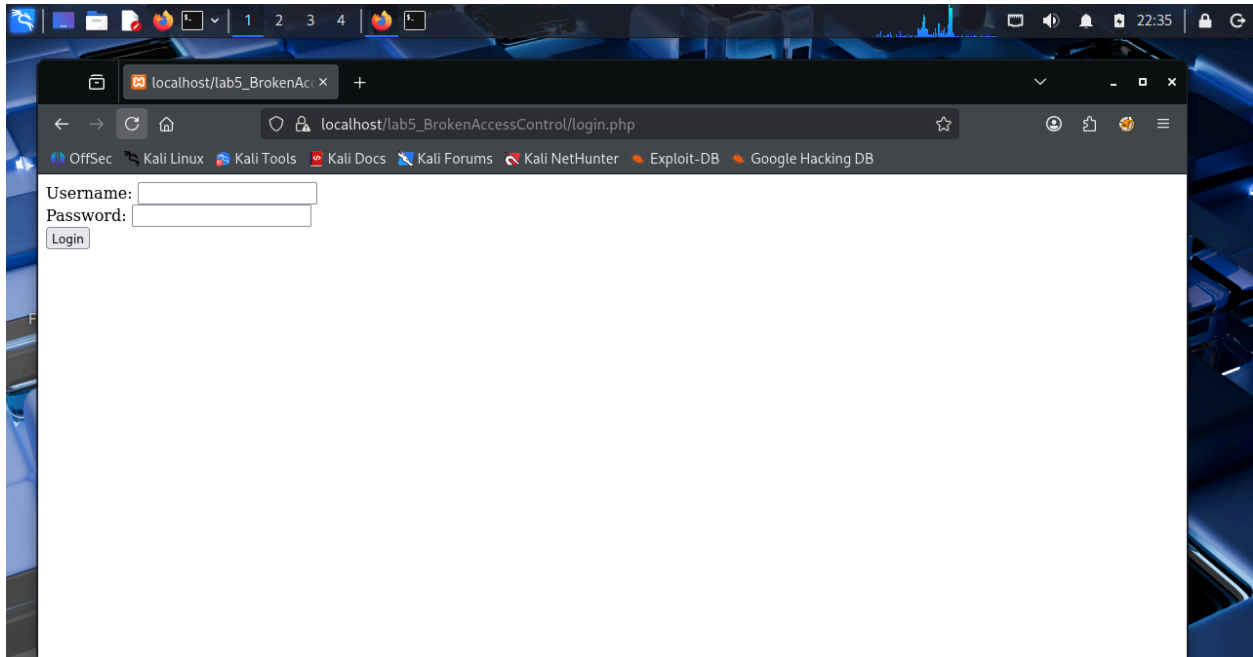
- Folder structure showing login.php, user_dashboard.php, and admin_dashboard.php.



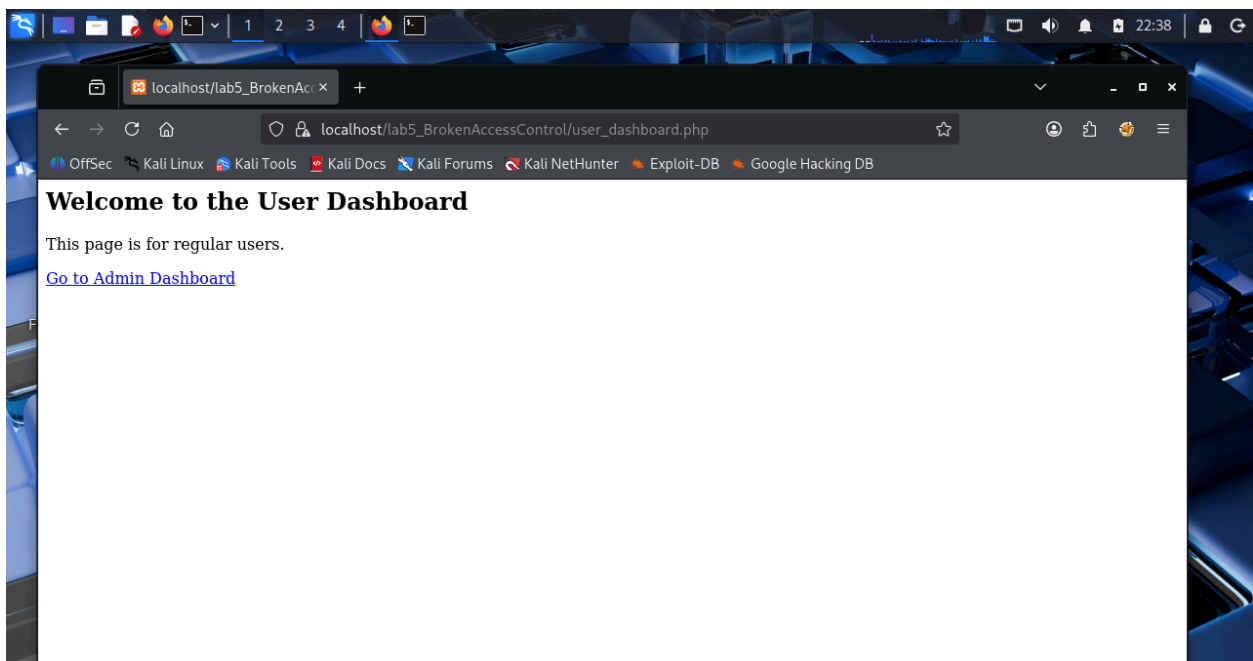
A terminal window on a Kali Linux desktop environment. The window title is 'kali@kali: /opt/lampp/htdocs/lab5_BrokenAccessControl'. The terminal shows the following commands and output:

```
kali@kali: /opt/lampp/htdocs/lab5_BrokenAccessControl
$ mkdir lab5_BrokenAccessControl
$ cd lab5_BrokenAccessControl
$ touch admin_dashboard.php
$ touch user_dashboard.php
$ ls
admin_dashboard.php  user_dashboard.php
$ touch login.php
$ ls -al
total 8
drwxrwxr-x  2 kali kali 4096 Jan 30 22:23 .
drwxrwxrwx 10 root root 4096 Jan 30 22:14 ..
-rw-rw-r--  1 kali kali   0 Jan 30 22:15 admin_dashboard.php
-rw-rw-r--  1 kali kali   0 Jan 30 22:23 login.php
-rw-rw-r--  1 kali kali   0 Jan 30 22:16 user_dashboard.php
```

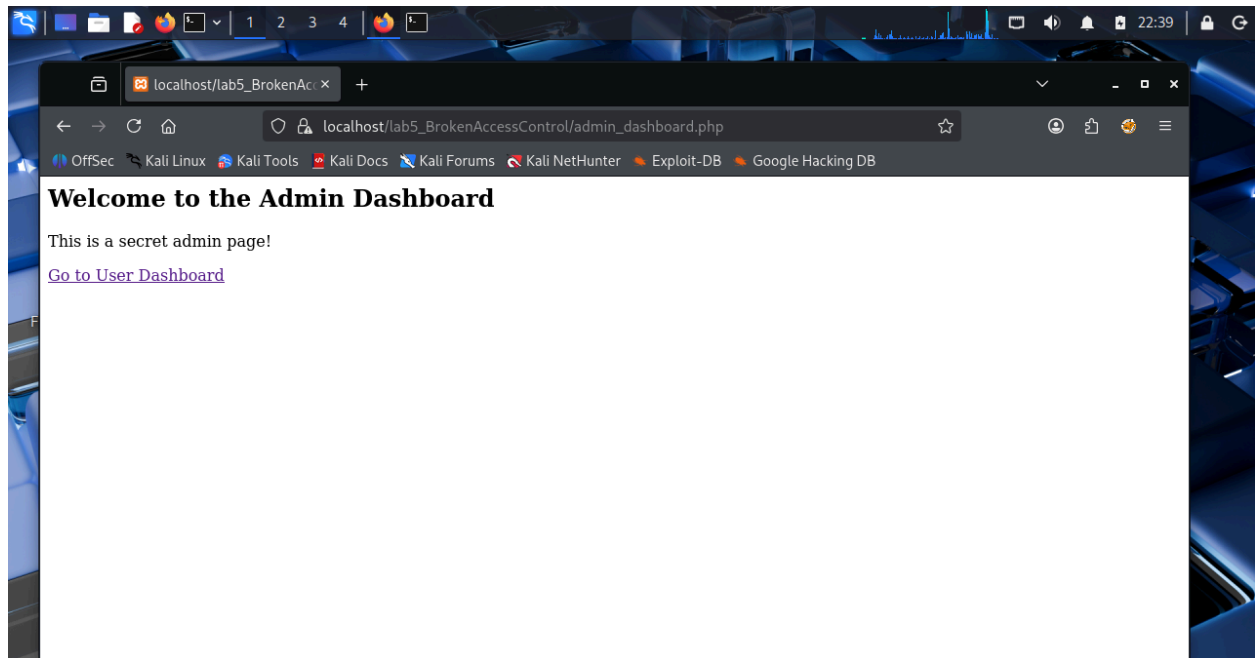
Login page displayed in browser.



User dashboard after logging in as regular user.



Admin dashboard accessed while logged in as a regular user.



Result

- Unauthorized access was successful.
- This confirms a Broken Access Control vulnerability.

Mitigating Broken Access Control

Mitigation Applied

- Added session checks.
- Verified user role before granting admin access.
- Restricted admin dashboard to admin users only.

Testing the Fix

- Logged in as regular user.
- Attempted to access admin dashboard.
- Access was denied.
- Logged in as admin.
- Admin dashboard loaded correctly.

Evidence

Updated admin_dashboard.php code showing role validation.



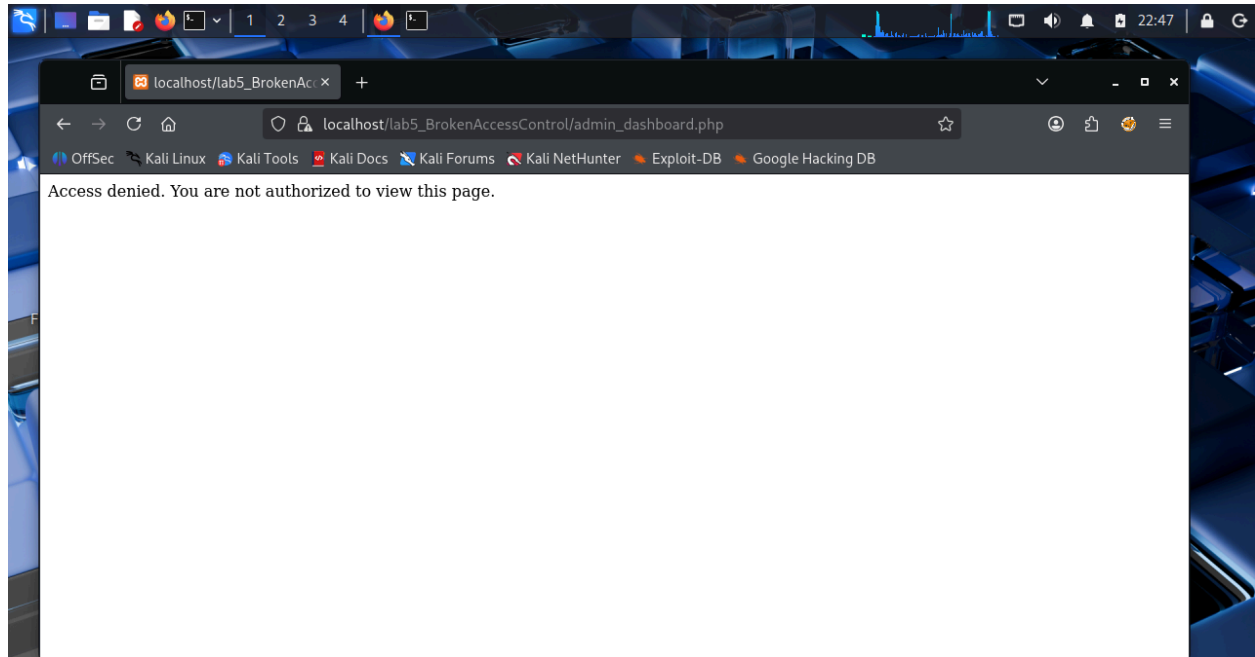
```
kali@kali: /opt/lampp/htdocs/lab5_BrokenAccessControl
GNU nano 8.7 admin_dashboard.php *
<?php
session_start();

if (!isset($_SESSION['username'])) { shboard
header("Location: login.php");
exit();
}

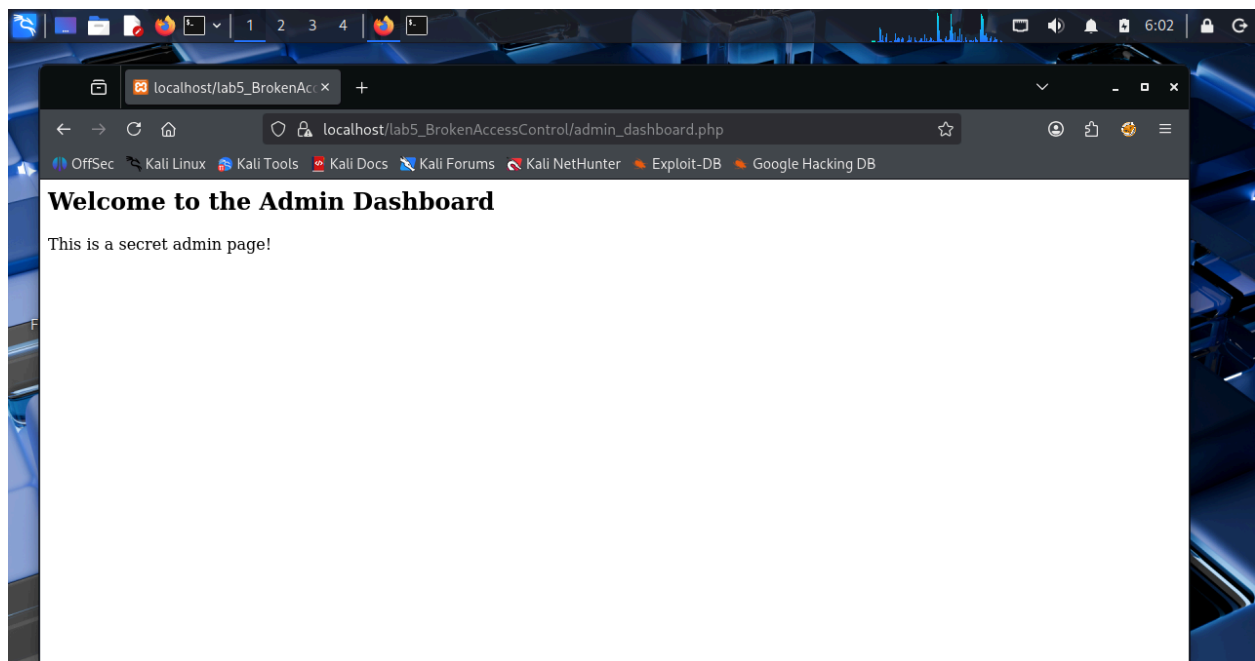
// Check if the user is an admin
if ($_SESSION['username'] !== 'admin') {
echo "<p>Access denied. You are not authorized to view this page.</p>";
exit();
}

echo "<h2>Welcome to the Admin Dashboard</h2>";
echo "<p>This is a secret admin page!</p>";
?>
```

Access denied message when regular user tries to access admin page.



Admin dashboard accessed successfully after admin login.



Result

- Unauthorized access was blocked.

- Proper access control was enforced.

Conclusion

Broken Access Control allows attackers to access sensitive resources.

Implementing proper authorization prevents privilege escalation.

Access control is critical for web application security.